Домашнее задание № 3

Статический анализ банковского TCP-сервера с помощью Semgrep

1. Цель и условия проверки

Цель: выполнить статический анализ main.py, разобрать срабатывания и предложить способы устранения выявленных проблем.

Среда	macOS; Semgrep 1.181.0; движок OSS
Объект	dz-3/main.py
Правила	Локальный каталог semgrep-rules/python
Результат	1 файл; 371 выполненное правило (по консоли)
Срабатывания	6: WARNING - 5, ERROR - 1
Ошибки проверки	Отсутствуют (errors: [])

Проверка выполнялась без запуска сервера. Анализ ограничен main.py, как указано в задании. Файлы клиента и демонстрационных атак не проверялись.

Подтверждение выполнения

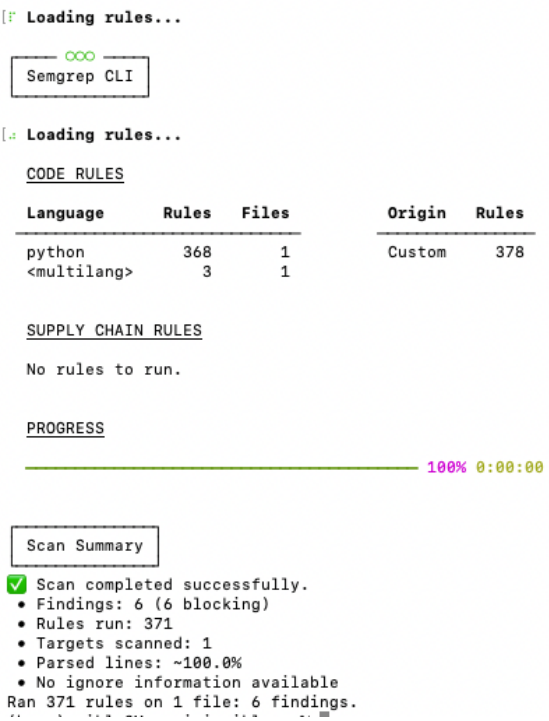


Рисунок 1 - Фрагмент предоставленного снимка консоли. Полный снимок включён в комплект материалов.

2. Результаты анализа

Шесть срабатываний по трём правилам. В таблице приведены короткие имена правил; полные идентификаторы сохранены в исходном JSON.

№ / строка	Правило / уровень	Анализ срабатывания	Рекомендация
1 / 52	insecure-hash-algorithm-md5 WARNING	MD5 при создании хеша пароля администратора. Быстрый алгоритм упрощает перебор паролей.	Использовать scrypt с индивидуальной случайной солью.
2 / 55	insecure-hash-algorithm-md5 WARNING	MD5 при создании хеша пароля alice. Проблема подтверждается просмотром кода.	Использовать scrypt с индивидуальной случайной солью.
3 / 58	insecure-hash-algorithm-md5 WARNING	MD5 при создании хеша пароля bob. Проблема подтверждается просмотром кода.	Использовать scrypt с индивидуальной случайной солью.
4 / 142	arbitrary-sleep ERROR	time.sleep(0.05) задерживает перевод. При отсутствии блокировки увеличивает окно гонки между чтением баланса и его использованием.	Удалить задержку; защитить проверку и изменение балансов одной блокировкой или транзакцией БД.
5 / 203	insecure-hash-algorithm-md5 WARNING	MD5 при вычислении хеша введённого пароля во время входа.	Перевести создание и проверку хешей на scrypt с солью.
6 / 203	md5-used-as-password WARNING	MD5 используется именно для пароля. Пересекается со срабатыванием № 5 на той же операции.	Исправляется вместе со срабатыванием № 5.

Правила MD5: security.insecure-hash-algorithm-md5 и security.audit.md5-used-as-password. Правило задержки: best-practice.arbitrary-sleep. Общий префикс: semgrep-rules.python.lang.

3. Вывод

В результате статического анализа файла main.py инструментом Semgrep версии 1.181.0 получено шесть срабатываний по трём правилам: пять уровня WARNING и одно уровня ERROR. Обнаружено использование MD5 при создании и проверке хешей паролей, а также искусственная задержка в функции перевода денежных средств. Два срабатывания на строке 203 относятся к одной операции. Рекомендуется заменить MD5 специализированным алгоритмом хеширования паролей с индивидуальной солью и обеспечить атомарность операций с балансами. Проверка завершилась без ошибок. Отсутствие других срабатываний не подтверждает безопасность приложения: статический анализ необходимо дополнять ручной проверкой и функциональными испытаниями.